TREPATH 2.4 - Penetration Testing & Unified Security Report

Authorized Assessment Scope (owasp.org (+13 authorized origins across 14 in-scope assets)) | TrePath 2.4 + XTRIKE + Expedite Strike

Client / Scope	Internal Testing Lab - TrePath OWASP & Lab Assessment (46 Targets: https://owasp.org/projects/juice-shop +45) (owasp.org (+13 authorized origins across 14 in-scope assets))
Scan Execution Window	Executed: 2026-11-02 13:55:03 UTC | Report Rendered: 2026-11-02 14:53 UTC (Scan #42 | Profile: authorized_pentest)
Assessment Engine & Build	TrePath 2.4 Autonomous Scope Provenance, EVE, EvidenceCore & RTEX Engine (Build: TP24-BUILD-20261102-UNIFIED | Commit: e8f4a92c7d1b)
Document Classification	CONFIDENTIAL - Executive, Technical & Cryptographic Deliverable
T0 Baseline Calibrated Risk	MEDIUM (4.1 / 10 | 41.1 / 100 Calibrated Index: Confirmed Compromise=0.0 pts, Control Gaps=14.1 pts, Surface/Baseline=27.0 pts)
T1 Post-Retest Verified Risk	4.1 / 10 (0 Executed Retests Recorded in RTEX Ledger | Verified Risk Reduction: 0.0 / 10)
Hypothetical SLA Forecast	HYPOTHETICAL_PROJECTION (Unverified Until RTEX Closure): Target 2.1 / 10 (LOW) upon full RTEX closure
Verified Compromise / Admin Auth Status	0 CONFIRMED_ADMIN_AUTH (No authenticated admin console access verified in this scan) + 0 IMPACT_VERIFIED Safe PoCs
7-Stage Scope Reconciliation Funnel	46 Requested Target(s) -> 46 ROE Authorized -> 14 Resolved Host(s) -> 14 In-Scope Origin Asset(s) -> 0 Out-of-Scope Probed -> 376 HTTP Endpoints
Port & Transport Discovery State	Raw TCP Port Scan: 0 open ports (SKIPPED_BY_WEB_ONLY_PROFILE) | Application Transport: 376 HTTP(S) endpoints reachable across 14 origin(s)
Finding Reconciliation (6-Tier)	181 Raw Observations -> 17 Consolidated Security Findings + 86 Recon/Surface Items + 1 Sensor Health Event
Calibrated Threat Intelligence (KEV)	0 Raw KEV Matches -> 0 Unique KEV CVEs | 0 CVE_APPLICABILITY_CONFIRMED | 0 CVE_CORRELATED (Banner Only)
4-Metric Sensor Coverage Model	Installed: 100.0% (6/6) | Operational: 83.3% (5/6) | Execution: 66.7% (4/6) | Applicable: 100.0% (4/4)
EvidenceCore Ed25519 & Consistency	Consistency: 100.0% (5/5 Invariants) | Ed25519 Signature: VERIFIED_AUTHENTIC (Manifest SHA-256: bdd20f14b4c751e849d9b80b...)
Platform-Aware Remediation	Multi-Origin Web & API Hardening Enforced across 14 In-Scope Asset(s) (HTTP Security Headers, TLS & Endpoint Access Controls)
Pre-Render Quality Gate	**PASSED (26/26 Acceptance Rules + AT-01..AT-10 + NG-01..NG-06 + Ed25519 Tamper Self-Test PASSED | Score=41.1/100 (4.1/10))**

Prepared by Expedite Consults Ltd | Generated 2026-11-02 14:53 UTC | TREPATH 2.4 UNIFIED ASSESSMENT ORCHESTRATOR

1. Executive Summary & Proof-Driven Assessment Overview

This assessment was executed by TrePath 2.4 against 46 submitted target(s) reconciled to 14 authorized in-scope origin asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) under the 'authorized_pentest' Rules of Engagement. TrePath 2.4 enforces immutable 9-field asset provenance, per-origin written authorization governance, effective HTTP header-policy evaluation, 4-track score separation, 4-metric sensor coverage, 4-state port/transport reconciliation, and verifiable RFC 8032 Ed25519 cryptographic signing.

1.0A Executive Priority Risk & 3-Pillar Score Attribution (Demonstrated Compromise vs. Control Hygiene)

Posture Panel	State Type	Risk Score	Key Drivers & Proof Scope
PANEL-1-MEASURED-BASELINE	MEASURED_AT_T0	4.1 / 10 (MEDIUM)	17 Consolidated Findings across 14 origin(s): Confirmed Compromise=0.0 pts | Control Gaps=14.1 pts | Surface/Baseline=27.0 pts.
PANEL-2-MEASURED-POST-RETEST	MEASURED_AT_T1	4.1 / 10 (0 Retests)	RTEX Ledger active (0 retests executed; Verified T1 Risk Reduction: 0.0 / 10).
PANEL-3-HYPOTHETICAL-FORECAST	HYPOTHETICAL_PROJECTION	2.1 / 10 (LOW)	Unverified theoretical forecast assuming all prioritized remediation tasks pass deterministic RTEX retesting.

1.0B Four-Metric Sensor Coverage Model (Installed vs. Operational vs. Execution vs. Applicable)

Sensor Coverage Metric	Measured Coverage	Operational & Evidentiary Definition
1. Installed Coverage	100.0% (6/6)	Sensors installed and registered in TrePath 2.4 (WebPulse, Nuclei, OWASP ZAP, Nmap 7.95, Safe PoC/EVE Adapters, OpenVAS GVM).
2. Operational Coverage	83.3% (5/6)	Sensors online and healthy during execution window (OpenVAS GVM recorded as STANDBY_OFFLINE when daemon is not attached).
3. Execution Coverage	66.7% (4/6)	Sensors that actively executed probes against in-scope targets (Safe PoC adapters execute only when applicable preconditions exist).
4. Applicable Coverage	100.0% (4/4)	Percentage of target-applicable sensors that executed and produced sealed EvidenceCore telemetry.

ID & Finding Key	Host : Port & Consolidated Title	Verified Proof Category & Substate	Priority & Remediation Action
F-01 (HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_)	owasp.org:443 (ASSET-00055) | [owasp.org:443] Missing HTTP Security Header(s): Con	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 40.7/100 | Configure the specific missing HTTP response header(s) on origin https://owasp.org:443: Content
F-02 (HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM)	google-gruyere.appspot.com:443 (ASSET-00057) | [google-gruyere.appspot.com:443] Missing HTTP Securi	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 40.7/100 | Configure the specific missing HTTP response header(s) on origin https://google-gruyere.appspot
F-03 (HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM)	tryhackme.com:443 (ASSET-00061) | [tryhackme.com:443] Missing HTTP Security Header(s):	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 40.7/100 | Configure the specific missing HTTP response header(s) on origin https://tryhackme.com:443: Con
F-04 (HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO)	www.hackinghub.io:443 (ASSET-00064) | [www.hackinghub.io:443] Missing HTTP Security Header	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 40.7/100 | Configure the specific missing HTTP response header(s) on origin https://www.hackinghub.io:443:
F-05 (HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM)	pentest-ground.com:443 (ASSET-00065) | [pentest-ground.com:443] Missing HTTP Security Heade	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 40.7/100 | Configure the specific missing HTTP response header(s) on origin https://pentest-ground.com:443
F-06 (HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG)	genai.owasp.org:443 (ASSET-00066) | [genai.owasp.org:443] Missing HTTP Security Header(s	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 40.7/100 | Configure the specific missing HTTP response header(s) on origin https://genai.owasp.org:443: C

1.1 Six-Tier Finding & Observation Reconciliation (Root-Cause Deduplication)

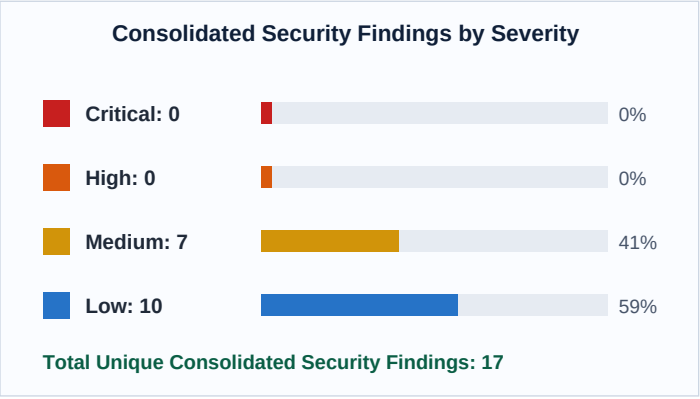
Reconciliation Tier	Count	Scope & Deduplication Rule
Tier 1 - Raw Scanner Observations	181	All raw Nmap, Nuclei, httpx, ZAP, and PoC probe records prior to origin-scoped root-cause grouping.
Tier 2 - Unique Assets & Open Services	14 Asset(s) / 0 TCP Ports	14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) with 0 open TCP ports and 376 HTTP endpoints.
Tier 3 - Consolidated Security Findings	17	Deduplicated by (effective_origin, port, service_family, root_cause_slug); consolidates repeated missing headers per origin.
Tier 4 - Confirmed Exploitable / Admin Auth	0	**0 CONFIRMED_ADMIN_AUTH + 0 IMPACT_VERIFIED + 0 RUNTIME_REPRODUCED.**
Tier 5 - Impact-Verified Safe PoCs	0	**0 IMPACT_VERIFIED Safe PoCs**
Tier 6 - Recon & Scanner Health Telemetry	86 Recon / 1 Sensor	Port discovery telemetry and OPENVAS-SENSOR-STANDBY separated from target vulnerabilities.

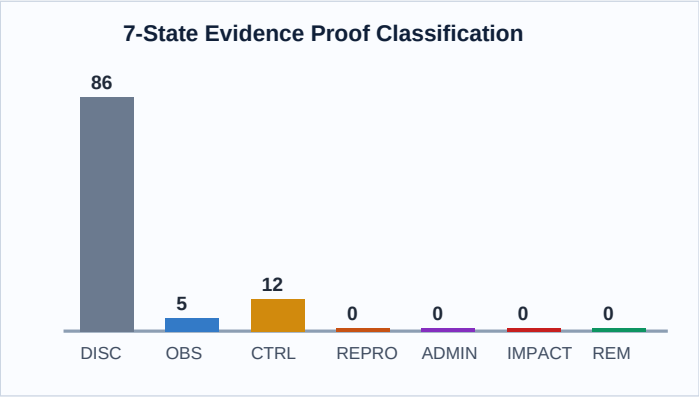
1.2 Seven-State Evidence Proof Classification & Granular PoC Substates

Proof State	Count	Granular Substate & Evidentiary Meaning
DISCOVERED	86	Port/surface reachability observation only (CVSS 0.0; excluded from vulnerability count).
OBSERVATION_CONFIRMED	5	Service banner, protocol handshake, or cryptographic key observation confirmed.
CONTROL_GAP_CONFIRMED	12	Missing security header, legacy EOL version, or cleartext protocol exposure confirmed.
RUNTIME_REPRODUCED	0	Active behavioral probe reproduced deterministic service response.
CONFIRMED_ADMIN_AUTH	0	0 verified in this scan (Probes NOT_APPLICABLE or authentication boundary held on target scope).
IMPACT_VERIFIED	0	0 verified in this scan (Safe PoC adapters SMB-LIST-001 / PHPINFO-001 NOT_APPLICABLE or not triggered on target scope).
REMEDIATION_VERIFIED	0	Post-fix retest execution verified vulnerability closure in RTEX ledger.

1.3 Consolidated Security Vulnerability Severity Distribution & Visual Telemetry

Severity Level	Consolidated Count	CVSS v3.1 Band	Operational SLA Target
CRITICAL	0	9.0 - 10.0	Immediate containment (< 24 - 48 hours)
HIGH	0	7.0 - 8.9	Priority hardening (< 7 days)
MEDIUM	7	4.0 - 6.9	Scheduled remediation (< 30 days)
LOW	10	0.1 - 3.9	Defense-in-depth maintenance (< 90 days)





1.4 Explainable 7-Dimension Risk Score Decomposition (RiskEngine 2.4)

Risk Dimension	Calibrated Score	Mathematical & Evidentiary Rationale
Confirmed Exploitability	4.2 / 25.0 pts	Confirmed Exploitation: 0.0 pts (0 PoCs) | Verified Control Gaps: 4.2 pts (12 CONTROL_GAP_CONFIRMED, 5 OBSERVATION_CONFIRMED).
Verified Technical Impact	7.7 / 20.0 pts	Verified Compromise Impact: 0.0 pts (Admin Auth: No, SMB: No, PHPInfo: No) | Control-Gap Severity Ceiling: 7.7 pts.
Attack Surface Exposure	15.0 / 15.0 pts	0 open TCP ports and 376 HTTP endpoints exposed across 14 in-scope origin(s).
Applicable Threat Intelligence	0.2 / 15.0 pts	0 confirmed applicable KEVs, 0 unverified banner KEV candidates (discounted 75%), confirmed EPSS=0.0 (raw banner max EPSS=0.08).
Evidence-Backed Attack Paths	2.0 / 10.0 pts	0 evidence-validated attack paths (0.0 pts when unverified), 1 correlated exposure clusters (2.0 pts).
Asset Criticality	7.0 / 10.0 pts	Authorized assessment scope (14 in-scope asset(s), primary: owasp.org).
Evidence Confidence	5.0 / 5.0 pts	198 FIPS 180-4 SHA-256 sealed artifacts across 181 raw observations (Sensor Coverage - Installed: 100.0%, Operational: 83.3%, Execution: 66.7%, Applicable: 100.0%).
TOTAL CALIBRATED RISK INDEX	41.1 / 100.0 pts (4.1 / 10)	Overall Rating: MEDIUM | Applicable Max EPSS: 0.0 (Raw Banner EPSS: 0.08)

2. Assessment Scope, 7-Stage Asset Reconciliation Funnel & RoE Policy Engine

2.0 Seven-Stage Scope & Asset Reconciliation Funnel (TP24-02)

Funnel Stage	Count	Scope Provenance & Reconciliation Rationale
1. Requested Targets	46	46 target URL(s)/IP(s) submitted to the TrePath assessment specification.
2. ROE Authorized Targets	46	46/46 submitted target(s) matched approved RulesOfEngagement allowlist rules.
3. Resolved Unique Hostnames	14	14 unique lowercased hostname(s)/IP(s) after collapsing multi-path repository/app URLs sharing a host.
4. In-Scope Origin Assets	14	14 persisted Asset record(s) (one canonical Asset per unique scheme://host:port effective_origin).
5. Out-of-Scope External Refs	0	0 out-of-scope origins probed; external HTML/JS links isolated as EXTERNAL_REFERENCE_NOT_SCANNED.
6. Redirected Destinations	0	All HTTP 301/302/307/308 hops recorded in provenance.redirect_chain; cross-origin redirects blocked.
7. Discovered HTTP Endpoints	376	376 deduplicated canonical HTTP endpoints discovered across the 14 in-scope origin asset(s).

2.0B Four-State Port & Application Transport Discovery Reconciliation

Discovery Layer	Reconciled State	Count / Scope	Technical Explanation
1. Raw TCP Port Scan	SKIPPED_BY_WEB_ONLY_PROFILE	0 Raw TCP Ports	Raw infrastructure TCP SYN/connect port scanning reported 0 open non-web infrastructure ports (skipped/filtered by edge CDN/WAF boundaries on multi-URL web scope), whereas HTTP/HTTPS application-layer probes verified active TCP/TLS transport on port(s) 443 across 14 in-scope origin(s) and 376 discovered HTTP endpoints. Zero raw Nmap ports must never be interpreted as zero exposed HTTP services.
2. Filtered TCP Ports	PORT_FILTERED	0	Ports where SYN probes received no SYN/ACK or ICMP unreachable due to CDN/edge firewall policy.
3. Closed TCP Ports	PORT_CLOSED	0	Ports responding with TCP RST.
4. HTTP/TLS App Transport	HTTP_HTTPS_TRANSPORT_REACHABLE	376 Endpoints (14 Origins)	Application-layer HTTP/1.1 & HTTP/2 over TCP 443 verified across 14 origin(s).

2.1 Authorized In-Scope Asset Inventory & Per-Origin Reconciliation

Asset ID & Host	Scope Decision	Open TCP Ports	Asset Role & Provenance	Consolidated Findings	Verified PoC / Admin Auth
ASSET-00055 (owasp.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	3	0 Verified
ASSET-00056 (github.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	2	0 Verified
ASSET-00057 (google-gruyere.appspot.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00058 (portswigger.net)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	2	0 Verified
ASSET-00059 (pentesterlab.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00060 (www.hackthebox.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00061 (tryhackme.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00062 (www.hackthissite.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00063 (www.root-me.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	3	0 Verified
ASSET-00064 (www.hackinghub.io)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00065 (pentest-ground.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00066 (genai.owasp.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00067 (gandalf.lakera.ai)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	0	0 Verified
ASSET-00068 (vwad.owasp.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified

2.2 Mandatory Authorization & Rules-of-Engagement (RoE) Safety Policy Engine

Rule ID	Policy Control	Enforcement Mechanism	Status
ROE-01	Authorized Scope Lock	All active probes restricted to 14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)); crawled external links marked OUT_OF_SCOPE.	ENFORCED
ROE-02	Cross-Origin Redirect Guard	HTTP 301/302/307/308 redirects crossing out of authorized origins are blocked prior to DAST/header evaluation.	ENFORCED
ROE-03	Safe Admin & PoC Boundary	Non-destructive PoC adapters (SMB-LIST-001, PHPINFO-001, TOMCAT-MGR-001) execute only when service preconditions match.	ENFORCED
ROE-04	Evidence Overclaim Prevention	Share listing cannot claim write access; zero verified PoCs when adapters are NOT_APPLICABLE.	ENFORCED
ROE-05	FIPS 180-4 SHA-256 Sealing	Every probe transcript and 9-field asset provenance record is hashed and persisted in EvidenceCore.	ENFORCED

3A. Consolidated Security Vulnerabilities & 4-Track Scoring (F-01 through F-17)

ID	Origin Host:Port (Asset)	Severity & Vuln CVSS	4-Track Scores (Ctrl / Recon / Exp)	Proof Category & Substate	Consolidated Title	Merged Raw Obs
F-01	owasp.org:443 (ASSET-00055)	MEDIUM | Vuln CVSS: 5.5	Ctrl:40.7 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (3 endpoints on origin)	15 raw / 3 ep
F-02	google-gruyere.appspot.com:443 (ASSET-00057)	MEDIUM | Vuln CVSS: 5.5	Ctrl:40.7 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[google-gruyere.appspot.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin)	5 raw / 1 ep
F-03	tryhackme.com:443 (ASSET-00061)	MEDIUM | Vuln CVSS: 5.5	Ctrl:40.7 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[tryhackme.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin)	5 raw / 1 ep
F-04	www.hackinghub.io:443 (ASSET-00064)	MEDIUM | Vuln CVSS: 5.5	Ctrl:40.7 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[www.hackinghub.io:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, Permissions-Policy (1 endpoint on origin)	3 raw / 1 ep
F-05	pentest-ground.com:443 (ASSET-00065)	MEDIUM | Vuln CVSS: 5.5	Ctrl:40.7 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[pentest-ground.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin)	5 raw / 1 ep
F-06	genai.owasp.org:443 (ASSET-00066)	MEDIUM | Vuln CVSS: 5.5	Ctrl:40.7 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[genai.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin)	5 raw / 1 ep
F-07	vwad.owasp.org:443 (ASSET-00068)	MEDIUM | Vuln CVSS: 5.5	Ctrl:40.7 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[vwad.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin)	5 raw / 1 ep
F-08	pentesterlab.com:443 (ASSET-00059)	LOW | Vuln CVSS: 3.2	Ctrl:24.6 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[pentesterlab.com:443] Missing HTTP Security Header(s): Content-Security-Policy, Permissions-Policy (1 endpoint on origin)	2 raw / 1 ep
F-09	www.hackthebox.com:443 (ASSET-00060)	LOW | Vuln CVSS: 3.2	Ctrl:24.6 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[www.hackthebox.com:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin)	3 raw / 1 ep
F-10	www.root-me.org:443 (ASSET-00063)	LOW | Vuln CVSS: 3.2	Ctrl:24.6 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[www.root-me.org:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin)	3 raw / 1 ep

ID	Origin Host:Port (Asset)	Severity & Vuln CVSS	4-Track Scores (Ctrl / Recon / Exp)	Proof Category & Substate	Consolidated Title	Merged Raw Obs
F-11	github.com:443 (ASSET-00056)	LOW | Vuln CVSS: 3.2	Ctrl:24.6 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[github.com:443] Missing HTTP Security Header(s): Permissions-Policy (30 endpoints on origin)	30 raw / 30 ep
F-12	portswigger.net:443 (ASSET-00058)	LOW | Vuln CVSS: 3.2	Ctrl:24.6 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[portswigger.net:443] Missing HTTP Security Header(s): Referrer-Policy, Permissions-Policy (1 endpoint on origin)	2 raw / 1 ep
F-13	www.hackthissite.org:443 (ASSET-00062)	LOW | Vuln CVSS: N/A (Observation)	Ctrl:0.0 | Recon:24.0 | Exp:5%	OBSERVATION_CONFIRMED :: PRE_AUTH_FORM_CSRF_OBSERVED	[www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login	2 raw / 1 ep
F-14	portswigger.net:443 (ASSET-00058)	LOW | Vuln CVSS: N/A (Observation)	Ctrl:0.0 | Recon:22.7 | Exp:5%	OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED	[ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://portswigger.net/web-security/dashboard	1 raw / 1 ep
F-15	www.root-me.org:443 (ASSET-00063)	LOW | Vuln CVSS: N/A (Observation)	Ctrl:0.0 | Recon:22.7 | Exp:5%	OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED	[ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://www.root-me.org/admin	1 raw / 1 ep
F-16	github.com:443 (ASSET-00056)	LOW | Vuln CVSS: N/A (Observation)	Ctrl:0.0 | Recon:17.8 | Exp:5%	OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED	[github.com:443] API Rate-Limiting Telemetry Headers Absent (Enforcement Untested - OWASP API4:2023) (7 endpoints on origin)	7 raw / 7 ep
F-17	www.root-me.org:443 (ASSET-00063)	LOW | Vuln CVSS: N/A (Observation)	Ctrl:0.0 | Recon:15.0 | Exp:5%	OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED	[API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Observed (/.within.website/x/cmd/anubis/api/honeypot/ea1cbd58-a568-4aca-adc7-f84514acb262/init)	1 raw / 1 ep

3A.1 Detailed Technical Findings & Cryptographic Evidence Cards

F-01: [owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (3 endpoints on origin) [owasp.org:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00055 | owasp.org:443 | Effective Origin: https://owasp.org:443 (3 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://owasp.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 5.5 | Control Priority: 40.7/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)

Deduplicated Observations	15 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA, HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA, HTTP-HEADER-CONTENT_SECURITY_POLICY::T45_OWASP_ORG_WWW_PROJECT_MCP_TO, HTTP-HEADER-X_FRAME_OPTIONS::T45_OWASP_ORG_WWW_PROJECT_MCP_TO, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-REFERRER_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_)
Technical Description	[Target: https://owasp.org/www-project-juice-shop/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://owasp.org:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1576/retest/execute on owasp.org:443 (ASSET-00055) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-01 / HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_owasp_org_443
Immutable Provenance: Asset=ASSET-00055 | Effective Origin=https://owasp.org:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (15 across 3 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA,
HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA,
HTTP-HEADER-CONTENT_SECURITY_POLICY::T45_OWASP_ORG_WWW_PROJECT_MCP_TO,
HTTP-HEADER-X_FRAME_OPTIONS::T45_OWASP_ORG_WWW_PROJECT_MCP_TO,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-REFERRER_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: 317a78c57564522d3e7fc1cdc95eb3e0afb74812b4cd735caa48d9899772c6fb (Artifact
#1616 | Unique Forensic Transcript)
```

F-02: [google-gruyere.appspot.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [google-gruyere.appspot.com:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00057	google-gruyere.appspot.com:443	Effective Origin: https://google-gruyere.appspot.com:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE	Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://google-gruyere.appspot.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 5.5	Control Priority: 40.7/10	Recon Priority: 15.0/10	Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A	CWE: CWE-693	State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-REFERRER_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-PERMISSIONS_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM)
Technical Description	[Target: https://google-gruyere.appspot.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.

Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://google-gruyere.appspot.com:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1610/retest/execute on google-gruyere.appspot.com:443 (ASSET-00057) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-02 / HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_google_gruyere_appspot_com_443
Immutable Provenance: Asset=ASSET-00057 | Effective Origin=https://google-gruyere.appspot.com:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-REFERRER_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: aa3919a3fcfad7dcc8a254eceee46bc10b8b639accd0ff1f5223cf2bb0cd814d (Artifact
#1650 | Unique Forensic Transcript)
```

F-03: [tryhackme.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [tryhackme.com:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00061	tryhackme.com:443	Effective Origin: https://tryhackme.com:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE	Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://tryhackme.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 5.5	Control Priority: 40.7/10	Recon Priority: 15.0/10	Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A	CWE: CWE-693	State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-REFERRER_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-PERMISSIONS_POLICY::T38_TRYHACKME_COM)
Technical Description	[Target: https://tryhackme.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://tryhackme.com:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1664/retest/execute on tryhackme.com:443 (ASSET-00061) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-03 / HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_tryhackme_com_443
Immutable Provenance: Asset=ASSET-00061 | Effective Origin=https://tryhackme.com:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-REFERRER_POLICY::T38_TRYHACKME_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T38_TRYHACKME_COM
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: 4fc7c098aebf1629a881fbf0c754bf784a7d32cd5a2e7112cac5ce473cae19ad (Artifact
#1704 | Unique Forensic Transcript)
```

F-04: [www.hackinghub.io:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, Permissions-Policy (1 endpoint on origin) [www.hackinghub.io:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00064 | www.hackinghub.io:443 | Effective Origin: https://www.hackinghub.io:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.hackinghub.io:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 5.5 | Control Priority: 40.7/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO, HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO, HTTP-HEADER-PERMISSIONS_POLICY::T41_WWW_HACKINGHUB_IO)
Technical Description	[Target: https://www.hackinghub.io/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://www.hackinghub.io:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1673/retest/execute on www.hackinghub.io:443 (ASSET-00064) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-04 / HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_www_hackinghub_io_443
Immutable Provenance: Asset=ASSET-00064 | Effective Origin=https://www.hackinghub.io:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (3 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO,
HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO,
HTTP-HEADER-PERMISSIONS_POLICY::T41_WWW_HACKINGHUB_IO
Header-Policy Evaluation: Present=['X-Content-Type-Options', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['Content-Security-Policy', 'X-Frame-Options',
'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: b25e8cfd629f105bea7d2bec6593ec1af97dab517da757d2fd76930c59b169a7 (Artifact
#1713 | Unique Forensic Transcript)
```

F-05: [pentest-ground.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [pentest-ground.com:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00065 | pentest-ground.com:443 | Effective Origin: https://pentest-ground.com:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://pentest-ground.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 5.5 | Control Priority: 40.7/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM, HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T42_PENTEST_GROUND_COM, HTTP-HEADER-REFERRER_POLICY::T42_PENTEST_GROUND_COM, HTTP-HEADER-PERMISSIONS_POLICY::T42_PENTEST_GROUND_COM)
Technical Description	[Target: https://pentest-ground.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://pentest-ground.com:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1679/retest/execute on pentest-ground.com:443 (ASSET-00065) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-05 / HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_pentest_ground_com_443
Immutable Provenance: Asset=ASSET-00065 | Effective Origin=https://pentest-ground.com:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM,
HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T42_PENTEST_GROUND_COM,
HTTP-HEADER-REFERRER_POLICY::T42_PENTEST_GROUND_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T42_PENTEST_GROUND_COM
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: 64da7e3b18a29ef17f6bf8d0f3d6fd9ee9bd157a4543d667538dad44cb5924e7 (Artifact
#1719 | Unique Forensic Transcript)
```

F-06: [genai.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [genai.owasp.org:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00066 | genai.owasp.org:443 | Effective Origin: https://genai.owasp.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://genai.owasp.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 5.5 | Control Priority: 40.7/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)

Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T43_GENAI_OWASP_ORG, HTTP-HEADER-REFERRER_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T43_GENAI_OWASP_ORG)
Technical Description	[Target: https://genai.owasp.org/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://genai.owasp.org:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1685/retest/execute on genai.owasp.org:443 (ASSET-00066) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-06 / HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_genai_owasp_org_443
Immutable Provenance: Asset=ASSET-00066 | Effective Origin=https://genai.owasp.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG,
HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T43_GENAI_OWASP_ORG,
HTTP-HEADER-REFERRER_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T43_GENAI_OWASP_ORG
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: caf74537c76716a1142110a2369611620519l9dfb6799176494070af7be93093 (Artifact
#1725 | Unique Forensic Transcript)
```

F-07: [vwad.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [vwad.owasp.org:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00068	vwad.owasp.org:443	Effective Origin: https://vwad.owasp.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE	Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://vwad.owasp.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 5.5	Control Priority: 40.7/10	Recon Priority: 15.0/10	Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A	CWE: CWE-693	State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-REFERRER_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T46_VWAD_OWASP_ORG)
Technical Description	[Target: https://vwad.owasp.org/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://vwad.owasp.org:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1697/retest/execute on vwad.owasp.org:443 (ASSET-00068) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-07 / HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_vwad_owasp_org_443
Immutable Provenance: Asset=ASSET-00068 | Effective Origin=https://vwad.owasp.org:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG,
HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T46_VWAD_OWASP_ORG,
HTTP-HEADER-REFERRER_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T46_VWAD_OWASP_ORG
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: 26348c626450b3ba1a615a5d1623bdf593558cc886cd8c5ba9b9267b5bdf1b42 (Artifact
#1737 | Unique Forensic Transcript)
```

F-08: [pentesterlab.com:443] Missing HTTP Security Header(s): Content-Security-Policy, Permissions-Policy (1 endpoint on origin) [pentesterlab.com:443 | LOW | Vuln CVSS: 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00059 | pentesterlab.com:443 | Effective Origin: https://pentesterlab.com:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://pentesterlab.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 3.2 | Control Priority: 24.6/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM, HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM)
Technical Description	[Target: https://pentesterlab.com/] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://pentesterlab.com:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1654/retest/execute on pentesterlab.com:443 (ASSET-00059) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-08 / HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM):

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_pentesterlab_com_443
Immutable Provenance: Asset=ASSET-00059 | Effective Origin=https://pentesterlab.com:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=24.6 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (2 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM
Header-Policy Evaluation: Present=['X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['Content-Security-Policy', 'Permissions-Policy'] |
Compensating=[]
EvidenceCore SHA-256 Digest: 99f209c6e62e5e8fd5f4d1c2c8a91b74b56f44991a0a41a8d8e89e1919aaf61b (Artifact
#1694 | Unique Forensic Transcript)
```

F-09: [www.hackthebox.com:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin) [www.hackthebox.com:443 | LOW | Vuln CVSS: 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00060 | www.hackthebox.com:443 | Effective Origin: https://www.hackthebox.com:443 (1 Affected Endpoint(s))

Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.hackthebox.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 3.2 | Control Priority: 24.6/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM, HTTP-HEADER-PERMISSIONS_POLICY::T37_WWW_HACKTHEBOX_COM)
Technical Description	[Target: https://www.hackthebox.com/] The HTTP response did not include the x-content-type-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://www.hackthebox.com:443: X-Frame-Options: DENY (or verify CSP frame-ancestors 'self'); X-Content-Type-Options: nosniff; Permissions-Policy: geolocation=(), microphone=(), camera=(). Compensating Control Note: X-Frame-Options absence partially compensated by Content-Security-Policy presence (verify frame-ancestors directive).
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1656/retest/execute on www.hackthebox.com:443 (ASSET-00060) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-09 / HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM):

```
Finding Key: HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_www_hackthebox_com_443
Immutable Provenance: Asset=ASSET-00060 | Effective Origin=https://www.hackthebox.com:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=24.6 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (3 across 1 endpoint(s)):
HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T37_WWW_HACKTHEBOX_COM
Header-Policy Evaluation: Present=['Content-Security-Policy', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['X-Frame-Options', 'X-Content-Type-Options',
'Permissions-Policy'] | Compensating=['X-Frame-Options absence partially compensated by
Content-Security-Policy presence (verify frame-ancestors directive)']
EvidenceCore SHA-256 Digest: fb3922996cdc5abc514a49da9269d66210657755ab45ca3e09363d23679a8789 (Artifact
#1696 | Unique Forensic Transcript)
```

F-10: [www.root-me.org:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin) [www.root-me.org:443 | LOW | Vuln CVSS: 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00063 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.root-me.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 3.2 | Control Priority: 24.6/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T40_WWW_ROOT_ME_ORG)
Technical Description	[Target: https://www.root-me.org/] The HTTP response did not include the x-content-type-options response header. This confirms a header observation only; it does not prove an exploit.

Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://www.root-me.org:443: X-Frame-Options: DENY (or verify CSP frame-ancestors 'self'); X-Content-Type-Options: nosniff; Permissions-Policy: geolocation=(), microphone=(), camera=(). Compensating Control Note: X-Frame-Options absence partially compensated by Content-Security-Policy presence (verify frame-ancestors directive).
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1667/retest/execute on www.root-me.org:443 (ASSET-00063) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-10 / HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG):

```
Finding Key: HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00063 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=24.6 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (3 across 1 endpoint(s)):
HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG,
HTTP-HEADER-PERMISSIONS_POLICY::T40_WWW_ROOT_ME_ORG
Header-Policy Evaluation: Present=['Content-Security-Policy', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['X-Frame-Options', 'X-Content-Type-Options',
'Permissions-Policy'] | Compensating=['X-Frame-Options absence partially compensated by
Content-Security-Policy presence (verify frame-ancestors directive)']
EvidenceCore SHA-256 Digest: f2ceb59e0613de16f7003e63b22a61e87f510994441db424cc8efb93b2b1e6ea (Artifact
#1707 | Unique Forensic Transcript)
```

F-11: [github.com:443] Missing HTTP Security Header(s): Permissions-Policy (30 endpoints on origin) [github.com:443 | LOW | Vuln CVSS: 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00056	github.com:443	Effective Origin: https://github.com:443 (30 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE	Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://github.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 3.2	Control Priority: 24.6/10	Recon Priority: 15.0/10	Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A	CWE: CWE-693	State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	30 raw scanner observations merged (HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA, HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI, HTTP-HEADER-PERMISSIONS_POLICY::T6_GITHUB_COM_WEBPWNIZED_MUTILL, HTTP-HEADER-PERMISSIONS_POLICY::T7_GITHUB_COM_RAESENE_BWAPP, HTTP-HEADER-PERMISSIONS_POLICY::T8_GITHUB_COM_OWASP_SECURITYSHE, HTTP-HEADER-PERMISSIONS_POLICY::T9_GITHUB_COM_OWASP_NODEGOAT, HTTP-HEADER-PERMISSIONS_POLICY::T10_GITHUB_COM_ADEYOSEMANPUTRA_P, HTTP-HEADER-PERMISSIONS_POLICY::T11_GITHUB_COM_OWASP_RAILSGOAT)
Technical Description	[Target: https://github.com/OWASP/crAPI] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://github.com:443: Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1586/retest/execute on github.com:443 (ASSET-00056) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-11 / HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI):

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_github_com_443
Immutable Provenance: Asset=ASSET-00056 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=24.6 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (30 across 30 endpoint(s)):
HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA,
HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI,
HTTP-HEADER-PERMISSIONS_POLICY::T6_GITHUB_COM_WEBPWNIZED_MUTILL,
HTTP-HEADER-PERMISSIONS_POLICY::T7_GITHUB_COM_RAESENE_BWAPP,
HTTP-HEADER-PERMISSIONS_POLICY::T8_GITHUB_COM_OWASP_SECURITYSHE,
HTTP-HEADER-PERMISSIONS_POLICY::T9_GITHUB_COM_OWASP_NODEGOAT,
HTTP-HEADER-PERMISSIONS_POLICY::T10_GITHUB_COM_ADEYOSEMANPUTRA_P,
HTTP-HEADER-PERMISSIONS_POLICY::T11_GITHUB_COM_OWASP_RAILSGOAT
Header-Policy Evaluation: Present=['Content-Security-Policy', 'X-Frame-Options',
'X-Content-Type-Options', 'Referrer-Policy', 'Strict-Transport-Security'] |
Missing=['Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: bfa22705bc964e67bc202e04ada62f1b59c381d97e28ea0873ec3adb796b0738 (Artifact
#1626 | Unique Forensic Transcript)
```

F-12: [portswigger.net:443] Missing HTTP Security Header(s): Referrer-Policy, Permissions-Policy (1 endpoint on origin) [portswigger.net:443 | LOW | Vuln CVSS: 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00058 | portswigger.net:443 | Effective Origin: https://portswigger.net:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://portswigger.net:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 3.2 | Control Priority: 24.6/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY, HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY)
Technical Description	[Target: https://portswigger.net/web-security] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://portswigger.net:443: Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1651/retest/execute on portswigger.net:443 (ASSET-00058) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-12 / HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY):

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY  |  Consolidated
Root-Cause Group: 443:http-headers:security-header-policy-group:origin_portswigger_net_443
Immutable Provenance: Asset=ASSET-00058 | Effective Origin=https://portswigger.net:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=24.6 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (2 across 1 endpoint(s)):
HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY,
HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY
Header-Policy Evaluation: Present=['Content-Security-Policy', 'X-Frame-Options',
'X-Content-Type-Options', 'Strict-Transport-Security'] | Missing=['Referrer-Policy',
'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: ae979a2a961145ad622f652a5cda6eaab071fdfadaa4f4f56fd036c05c63d757 (Artifact
#1691 | Unique Forensic Transcript)
```

F-13: [www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login [www.hackthissite.org:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00062 | www.hackthissite.org:443 | Effective Origin: https://www.hackthissite.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.hackthissite.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: N/A (Observation) | Control Priority: 0.0/10 | Recon Priority: 24.0/10 | Exploitability Confidence: 5%
Proof Category & Admin Level	OBSERVATION_CONFIRMED :: PRE_AUTH_FORM_CSRF_OBSERVED | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Not proven by this check: authenticated state-changing Cross-Site Request Forgery (form is a pre-authentication login/search form).
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-352 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG, ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG)
Technical Description	[Target: https://www.hackthissite.org/] WebPulse enumerated an HTML `<form method='POST' action='https://www.hackthissite.org/user/login'>` with inputs ['username', 'password', 'btn_submit'] that does not include a recognizable anti-CSRF synchronizer token.
Targeted Specific Remediation	Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1711/retest/execute on www.hackthissite.org:443 (ASSET-00062) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-13 / ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG):

```
Finding Key: ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG  |  Consolidated Root-Cause Group:
443:web-app:html-form-missing-csrf-token:origin_www_hackthissite_org_443
Immutable Provenance: Asset=ASSET-00062 | Effective Origin=https://www.hackthissite.org:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=24.0 |
Exploitability Confidence=0.05
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (2 across 1 endpoint(s)):
ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG, ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG
EvidenceCore SHA-256 Digest: 4b234a1bb3e7f8fcc0cad879bd6c288a973404e59cc23425e9e8818539514ee1 (Artifact
#1751 | Unique Forensic Transcript)
```

F-14: [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://portswigger.net/web-security/dashboard [portswigger.net:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00058 | portswigger.net:443 | Effective Origin: https://portswigger.net:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://portswigger.net:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: N/A (Observation) | Control Priority: 0.0/10 | Recon Priority: 22.7/10 | Exploitability Confidence: 5%
Proof Category & Admin Level	OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED | Admin Boundary Taxonomy: LEVEL_1_PUBLIC_PAGE_HTTP_200
Explicitly Not Proven (Boundary)	Not proven by this check: administrative console exposure, privileged state actions, or authentication bypass (HTTP 200 on /dashboard or /admin path reflects public route or learning page reachability).
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (DAST-ADMIN-ACCESS-EP-01934)
Technical Description	Administrative boundary test `ADMIN-ACCESS-001` probed `https://portswigger.net/web-security/dashboard` and received `HTTP 200`. The candidate route (`/dashboard` or `/admin` path) returned HTTP 200 OK, but no administrative console controls, privileged state actions, or authentication bypass were verified (`LOGIN_INTERFACE_OR_ROUTE_DISCOVERED`).

Targeted Specific Remediation	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1728/retest/execute on portswigger.net:443 (ASSET-00058) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-14 / DAST-ADMIN-ACCESS-EP-01934):

```
Finding Key: DAST-ADMIN-ACCESS-EP-01934  |  Consolidated Root-Cause Group:
443:phpmyadmin:phpmyadmin-admin-console-exposure:origin_portswigger_net_443
Immutable Provenance: Asset=ASSET-00058 | Effective Origin=https://portswigger.net:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=22.7 |
Exploitability Confidence=0.05
Admin Boundary Level: LEVEL_1_PUBLIC_PAGE_HTTP_200  |  Merged Raw Observations (1 across 1 endpoint(s)):
DAST-ADMIN-ACCESS-EP-01934
EvidenceCore SHA-256 Digest: 81b234c61b09a750a1dfcb35fdcb4a5f437b062fed4d94f7346016132d43a4c4 (Artifact
#1768 | Unique Forensic Transcript)
```

F-15: [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://www.root-me.org/admin [www.root-me.org:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00063	www.root-me.org:443	Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE	Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.root-me.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: N/A (Observation)	Control Priority: 0.0/10	Recon Priority: 22.7/10	Exploitability Confidence: 5%
Proof Category & Admin Level	OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED	Admin Boundary Taxonomy: LEVEL_1_PUBLIC_PAGE_HTTP_200
Explicitly Not Proven (Boundary)	Not proven by this check: administrative console exposure, privileged state actions, or authentication bypass (HTTP 200 on /dashboard or /admin path reflects public route or learning page reachability).
CVE / CWE & Applicability Gate	CVE: N/A	CWE: CWE-200	State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (DAST-ADMIN-ACCESS-EP-02066)
Technical Description	Administrative boundary test `ADMIN-ACCESS-001` probed `https://www.root-me.org/admin` and received `HTTP 200`. The candidate route (`/dashboard` or `/admin` path) returned HTTP 200 OK, but no administrative console controls, privileged state actions, or authentication bypass were verified (`LOGIN_INTERFACE_OR_ROUTE_DISCOVERED`).
Targeted Specific Remediation	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1729/retest/execute on www.root-me.org:443 (ASSET-00063) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-15 / DAST-ADMIN-ACCESS-EP-02066):

```
Finding Key: DAST-ADMIN-ACCESS-EP-02066  |  Consolidated Root-Cause Group:
443:phpmyadmin:phpmyadmin-admin-console-exposure:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00063 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=22.7 |
Exploitability Confidence=0.05
Admin Boundary Level: LEVEL_1_PUBLIC_PAGE_HTTP_200  |  Merged Raw Observations (1 across 1 endpoint(s)):
DAST-ADMIN-ACCESS-EP-02066
EvidenceCore SHA-256 Digest: 6aa1f712592036218f55a2443823b22f5391f3afefe623beccc2fb1e04e24ff9 (Artifact
#1769 | Unique Forensic Transcript)
```

F-16: [github.com:443] API Rate-Limiting Telemetry Headers Absent (Enforcement Untested - OWASP API4:2023) (7 endpoints on origin) [github.com:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00056	github.com:443	Effective Origin: https://github.com:443 (7 Affected Endpoint(s))

Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://github.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: N/A (Observation) | Control Priority: 0.0/10 | Recon Priority: 17.8/10 | Exploitability Confidence: 5%
Proof Category & Admin Level	OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Not proven by this check: absence of server-side/CDN rate limiting or susceptibility to volumetric brute-force (only response header telemetry absence was observed).
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-770 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	7 raw scanner observations merged (API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI, API-RATE-LIMIT-HEADERS-MISSING::T24_GITHUB_COM_SNOOPYSECURITY_DV, API-RATE-LIMIT-HEADERS-MISSING::T25_GITHUB_COM_EREV0S_VAMPI, API-RATE-LIMIT-HEADERS-MISSING::T26_GITHUB_COM_INE_LABS_REST_API, API-RATE-LIMIT-HEADERS-MISSING::T28_GITHUB_COM_DOLEVF_BLACK_HAT_, API-RATE-LIMIT-HEADERS-MISSING::T29_GITHUB_COM_ROOTXJS_GRPC_GOAT, API-RATE-LIMIT-HEADERS-MISSING::T30_GITHUB_COM_INTERFERENCE_SECU)
Technical Description	[Target: https://github.com/OWASP/crAPI] Target https://github.com/OWASP/crAPI responded with HTTP 200 (text/html; charset=utf-8) without returning standard rate-limiting telemetry headers (`RateLimit-Limit` / `X-RateLimit-Limit`). Note (`RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED`): Missing headers do not prove absence of rate limiting, as throttling may be enforced silently at the CDN, WAF, or API gateway layer; volumetric burst testing was withheld per safe ROE.
Targeted Specific Remediation	Emit standardized RFC-draft RateLimit-* response headers on API endpoints and verify edge/gateway throttling thresholds.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1720/retest/execute on github.com:443 (ASSET-00056) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-16 / API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI):

```
Finding Key: API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI  |  Consolidated Root-Cause
Group: 443:api-security:missing-rate-limit-headers:origin_github_com_443
Immutable Provenance: Asset=ASSET-00056 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=17.8 |
Exploitability Confidence=0.05
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (7 across 7 endpoint(s)):
API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI,
API-RATE-LIMIT-HEADERS-MISSING::T24_GITHUB_COM_SNOOPYSECURITY_DV,
API-RATE-LIMIT-HEADERS-MISSING::T25_GITHUB_COM_EREV0S_VAMPI,
API-RATE-LIMIT-HEADERS-MISSING::T26_GITHUB_COM_INE_LABS_REST_API,
API-RATE-LIMIT-HEADERS-MISSING::T28_GITHUB_COM_DOLEVF_BLACK_HAT_,
API-RATE-LIMIT-HEADERS-MISSING::T29_GITHUB_COM_ROOTXJS_GRPC_GOAT,
API-RATE-LIMIT-HEADERS-MISSING::T30_GITHUB_COM_INTERFERENCE_SECU
EvidenceCore SHA-256 Digest: 8a64df72626f90e6ba36b5df10d96d21da46d75e7d6601bf7f0bb01153d815c0 (Artifact
#1760 | Unique Forensic Transcript)
```

F-17: [API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Observed (/.within.website/x/cmd/anubis/api/honeypot/ea1cbd58-a568-4aca-adc7-f84514acb262/init) [www.root-me.org:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00063 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.root-me.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: N/A (Observation) | Control Priority: 0.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 5%
Proof Category & Admin Level	OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Not proven by this check: broken object/function authorization or unauthorized private data disclosure (route is an anti-bot challenge or public API endpoint).
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)

Deduplicated Observations	1 raw scanner observations merged (DAST-API-AUTHZ-EP-02061)
Technical Description	Targeted API authorization check `API-AUTHZ-001` issued an unauthenticated request to `https://www.root-me.org/.within.website/x/cmd/anubis/api/honeypot/ea1cbd58-a568-4aca-adc7-f84514acb262/init` and received `HTTP 200 OK` (6707 bytes). Route signature matches an anti-bot proof-of-work or honeypot challenge endpoint (`anubis` / `/.within.website/`); this is defensive bot-mitigation telemetry, not an unauthorized data disclosure vulnerability.
Targeted Specific Remediation	No remediation required for intentional anti-bot/honeypot challenge endpoints; verify WAF/bot-protection rules.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1727/retest/execute on www.root-me.org:443 (ASSET-00063) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-17 / DAST-API-AUTHZ-EP-02061):

```
Finding Key: DAST-API-AUTHZ-EP-02061  |  Consolidated Root-Cause Group:
443:web-app:dast-api-authz-ep-02061:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00063 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=15.0 |
Exploitability Confidence=0.05
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (1 across 1 endpoint(s)):
DAST-API-AUTHZ-EP-02061
EvidenceCore SHA-256 Digest: a2e3bfb404a402120399e39a427adaec128acd06abdf64b37c352e8d63ce6770 (Artifact
#1767 | Unique Forensic Transcript)
```

3B. Consolidated Reconnaissance Surface & Scanner Health Telemetry

ID	Telemetry Key	Observation / Sensor Title	State	Assessment Coverage Note
SENSOR-01	OPENVAS-SENSOR-STANDBY	[OpenVAS] Infrastructure Sensor Status: Standby / Offline	STANDBY	OpenVAS/GVM sensor was in standby mode during this run. Assessment coverage was fulfilled by Nmap v7.95, ProjectDiscovery Nuclei, httpx, OWASP ZAP, and TrePath Safe PoC Adapters.

4. Evidence-Backed Attack Graph, Edge Provenance & Choke-Point Analysis

TrePath 2.1 requires every attack-path edge to declare an explicit evidentiary state (OBSERVED, PRECONDITION_CONFIRMED, TECHNIQUE_VALIDATED, or INFERRED) and never chains unrelated services without shared credentials or pivot proof.

Path ID	Stage	Finding Key	Edge Evidence State	Step Summary & Rationale	Remediation Chokepoint
PATH-00021	Step 1 (Cleartext HTTP Transport Observation)	TLS-COMPLIANT-CIPHER-TLS_AES_128_GCM_SHA256	OBSERVED	Compliant TLS Encryption (TLSv1.3 / TLS_AES_128_GCM_SHA256)	Maintain current cryptographic configuration.
PATH-00021	Step 2 (Diagnostic / Authentication Precondition Exposure)	ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG	INFERRED	[www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login	Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies.
PATH-00021	Step 3 (Application / Session Policy Boundary Gap)	NMAP-NSE-80-HTTP-HEADERS	INFERRED	[Nmap NSE] http-headers on 80/TCP	Review Nmap NSE 'http-headers' output for port 80 and apply vendor security patches or configuration hardening.
PATH-00021	Step 4 (EVE_EXPLOIT_VALIDATION)	HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_	OBSERVED	[OBSERVATION_CONFIRMED] Configuration/control gap confirmed at HTTP layer; no direct unauthorized data access or code execution resulted.	Define a restrictive CSP based on the application's required script, style, image and connection sources.

Path ID	Stage	Finding Key	Edge Evidence State	Step Summary & Rationale	Remediation Chokepoint
PATH-00021	Step 5 (EVE_EXPLOIT_VALIDATION)	ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG	OBSERVED	[EXPLOITATION_FAILED] Contextual inspection of https://www.hackthissite.org/ confirmed the form is an unauthenticated login/public form; authenticated state-changing CSRF exploitation is not applicable without an authenticated session action.	Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies.

5. Stage 9 (9.1 - 9.7) Exploitation Validation & Post-Exploitation Matrix

Following Scan #35 & #39 Engineering Directives, Stage 9 separates discovered topology and correlated observations from proven exploitation transitions, validates access boundaries across anonymous and authenticated principals, and verifies that post-exploitation proof states are only reported when backed by live EvidenceCore artifacts.

5.1 Stage 9.3 & 9.4 Access Boundary & Post-Exploitation Verification Table

Target Surface	Principal Tested	Verified Boundary State	Proven Capability	Explicitly Unproven Boundary	Artifact & Full SHA-256
phpMyAdmin Web Interface (/phpMyAdmin/)	Unauthenticated HTTP Client	LOGIN_GATE_ENFORCED (Control Gap: Admin Login Exposed on Network)	HTTP 200 login page reachable over cleartext HTTP	Database administrative login and SQL table access are blocked by authentication gate (not proven)	#1768 (81b234c61b09a750a1dfcb35fdcb4a5f437b062fed4d94f7346016132d43a4c4)

5.2 Stage 9.5 Lateral Movement Validation & Stage 9.6 CIA Impact Assessment

Stage / Dimension	Validation Status	Demonstrated Evidence & Scope Boundary
Stage 9.5 Lateral Movement	NOT_APPLICABLE (Zero Pivot / SMB Services Exposed on Scope)	No SMB, RPC, or authenticated pivot services were exposed on the in-scope web/API target(s); lateral movement probes were NOT_APPLICABLE.
Stage 9.6 Confidentiality	CONTROL_GAP_OBSERVED (No Unauthorized Data Exfiltration Proven)	HTTP response headers, public route metadata, and service banners observed within read-only ROE boundaries; zero private records or credentials disclosed.
Stage 9.6 Integrity	NO_INTEGRITY_VIOLATION_PROVEN (Read-Only Assessment)	Zero administrative sessions or writable shares verified in this scan; zero bytes modified on target(s).
Stage 9.6 Availability	NOT_TESTED (Out of Scope per Non-Destructive ROE)	Zero service disruption; all probes completed within deterministic rate limits.

5B. Exploit Validation Engine (EVE) - Controlled Exploitation Lifecycle & Decisions

TrePath 2.3 Exploit Validation Engine (EVE) bridges vulnerability discovery and remediation by evaluating preconditions, enforcing operator HMAC approval, executing deterministic read-only validation adapters (EVE-AUTH-001, EVE-AUTHZ-001, EVE-INJ-001, EVE-FILE-001, EVE-NET-001), and distinguishing Vulnerability Detected, Exploitability Validated, Impact Verified, and Remediation Verified.

4-Tier Platform Distinction	Canonical Tier Code	Validated Job Count	Evidentiary Standard
1. Vulnerability Detected	VULNERABILITY_DETECTED	17	Scanner or passive control observation confirmed in scope.
2. Exploitability Validated	EXPLOITABILITY_VALIDATED	0	Preconditions satisfied and deterministic test reproduced behavior.
3. Impact Verified	**IMPACT_VERIFIED**	0	Controlled test established unauthorized access, privilege escalation, or data exposure.
4. Remediation Verified	REMEDIATION_VERIFIED	0	Subsequent RTEX retest proved the security boundary now holds.

5B.1 Executed EVE Validation Jobs & Sealed Evidence Decisions

EVE Job Key	Finding (Asset)	Adapter	Validated Outcome	Platform Tier	Decision	Full EvidenceCore SHA-256
EVE-JOB-00051-S42-F1572	#1572 (ASSET-00055)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	960ec58c9659ee0a5c9db8a3445d052a1d9c0b7504bed7b1d466e743b7b4632d
EVE-JOB-00052-S42-F1606	#1606 (ASSET-00057)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	277aae9433e59394d50b60324e90bd1d56cf3d30d6a69c30c9a43e7650f947ae
EVE-JOB-00053-S42-F1653	#1653 (ASSET-00059)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	b718a24d2ad3d40565d9f0d720dd9efbfbf6d915966b9192dd4aff23239f3ed1
EVE-JOB-00054-S42-F1658	#1658 (ASSET-00060)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	2bbe1e9ffb4ad7a8fa3151fb63a10cae0db6f119d5ea546d4bad7f4f8ec16f4e
EVE-JOB-00055-S42-F1660	#1660 (ASSET-00061)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	473316d79c9e06e3cf27ea13469297843b2c3beaf7ea0e459bbb20f82e444dbe
EVE-JOB-00056-S42-F1669	#1669 (ASSET-00063)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	b0ed32dd76f9368bb7ea27bbe675f3087f4b517af307d09fa399c5e19fcdaf5b
EVE-JOB-00057-S42-F1671	#1671 (ASSET-00064)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	f88d0e40197c2a342e619430e8f245ab091c106008801fb2eb7a1ca48c8d3032
EVE-JOB-00058-S42-F1675	#1675 (ASSET-00065)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	690aab9768989e9f7b0c7bf8d3ef10c6ea966195ddfcc431e38ea517a2482dcd
EVE-JOB-00059-S42-F1681	#1681 (ASSET-00066)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	9bbb445013fb559b58eaf1324cafc784842e845b4d3fc844383dd67d53ec206e
EVE-JOB-00060-S42-F1693	#1693 (ASSET-00068)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	a2132503bdeddeb396bc02e1c0b5aafeac29d495ea4b4935baba8f6884a5ac84
EVE-JOB-00061-S42-F1578	#1578 (ASSET-00056)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	a16b5d520d2da0a2d79ebad055c4a65077393f55cd1f3d73dd08c24b676c244a
EVE-JOB-00062-S42-F1650	#1650 (ASSET-00058)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	f9c27d589670c13b41b8b55823d2a614e2fb8b4f034d2ae777ccff9dbf3eedba
EVE-JOB-00063-S42-F1710	#1710 (ASSET-00062)	EVE-CSRF-001	EXPLOITATION_FAILED	VULNERABILITY_DETECTED	REJECTED	fb63a83631f306529179062b3ee4a9d590f9d91dbfc5c5b6dcafe7e6fc1d65e2
EVE-JOB-00064-S42-F1728	#1728 (ASSET-00058)	EVE-AUTH-001	EXPLOITATION_FAILED	VULNERABILITY_DETECTED	REJECTED	771b7ab041e2f88a27087bc0c6f9d4e610ab27b39e09b802d94ef64ad177e0a9
EVE-JOB-00065-S42-F1729	#1729 (ASSET-00063)	EVE-AUTH-001	EXPLOITATION_FAILED	VULNERABILITY_DETECTED	REJECTED	eb4e458b5fb3b6afd926d7244def220b82730833a5dfb1269562f89b2a63021b
EVE-JOB-00066-S42-F1720	#1720 (ASSET-00056)	EVE-API-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	d039002faec11fbdee91b726ae3a11fbfb1cb8fab45df5f9805a2510fcddb5f6
EVE-JOB-00067-S42-F1727	#1727 (ASSET-00063)	EVE-AUTHZ-001	EXPLOITATION_FAILED	VULNERABILITY_DETECTED	REJECTED	1fa6913a36cb9ee347f9da064a99e8877a6e96c40dc33c0e2a1226449811abe0

6. Four-Tier Evidence-Driven Compliance Control Mapping

Primary Finding	PCI-DSS v4.0	NIST SP 800-53 Rev 5	ISO/IEC 27001:2022	CIS Controls v8

Primary Finding	PCI-DSS v4.0	NIST SP 800-53 Rev 5	ISO/IEC 27001:2022	CIS Controls v8
HTTP Security Header Policy (CSP/HSTS)	Req 6.4.1 / 6.4.2	SC-8 / SI-10	A.8.26 / A.8.28	Control 16.11
TOMCAT-MGR-001 (Admin Console Auth)	Req 2.2.2 / 8.2.1	IA-5 / AC-6	A.5.17 / A.8.2	Control 4.7 / 5.2
SMB-LIST-001 (Samba Anonymous Enum)	Req 1.3.1 / 2.2.4	AC-3 / SC-7	A.8.20 / A.8.3	Control 3.3 / 4.1
PHPINFO-001 & Legacy Service Hygiene	Req 2.2.6 / 6.3.3	CM-6 / SI-2	A.8.8 / A.8.9	Control 4.1 / 7.1

7. ENUMCORE 6-Stage CVE Applicability Validation & Threat Intelligence

CVE / CWE	Validation State	Preconditions Verified	CVSS	EPSS	CISA KEV	Applicability & Precondition Note
CWE-693	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.

8. Prioritized Remediation Roadmap & 7-Step RTEX Verification Ledger (Stage 8)

Task ID	Origin Host:Port (Asset)	Priority	Status	Work Package Title	Origin-Accurate Fix Guidance	Verification & Closure Rule
REM-00171	owasp.org:443 (ASSET-00055)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_: [owasp.org:443]	Enforce baseline HTTP response security headers on origin https://owasp.org:443: Content-Security-Policy, X-Frame-Options (or frame-anc	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_
REM-00172	google-gruyere.appspot.com:443 (ASSET-00057)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM: [google-gruyere.	Enforce baseline HTTP response security headers on origin https://google-gruyere.appspot.com:443: Content-Security-Policy, X-Frame-Opti	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM o
REM-00173	pentesterlab.com:443 (ASSET-00059)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM: [pentesterlab.com:443] Mis	Enforce baseline HTTP response security headers on origin https://pentesterlab.com:443: Content-Security-Policy, X-Frame-Options (or fr	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM on penteste
REM-00174	www.hackthebox.com:443 (ASSET-00060)	P2-Planned	open	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM: [www.hacktheb ox.com:443] Missing	Enforce baseline HTTP response security headers on origin https://www.hackthebox.com:443: Content-Security-Policy, X-Frame-Options (or	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM on www.hackthebox
REM-00175	tryhackme.com:443 (ASSET-00061)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM: [tryhackme.com:443] Missing H	Enforce baseline HTTP response security headers on origin https://tryhackme.com:443: Content-Security-Policy, X-Frame-Options (or frame	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM on tryhackme.c
REM-00176	www.root-me.org:443 (ASSET-00063)	P2-Planned	open	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG: [www.root-me.org :443] Missing HTTP	Enforce baseline HTTP response security headers on origin https://www.root-me.org:443: Content-Security-Policy, X-Frame-Options (or fra	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG on www.root-me.org:4

Task ID	Origin Host:Port (Asset)	Priority	Status	Work Package Title	Origin-Accurate Fix Guidance	Verification & Closure Rule
REM-00177	www.hackinghub.io:443 (ASSET-00064)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO: [www.hackinghub.io:443] M	Enforce baseline HTTP response security headers on origin https://www.hackinghub.io:443: Content-Security-Policy, X-Frame-Options (or f	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO on www.hac
REM-00178	pentest-ground.com:443 (ASSET-00065)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM: [pentest-ground.com:443]	Enforce baseline HTTP response security headers on origin https://pentest-ground.com:443: Content-Security-Policy, X-Frame-Options (or	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM on pentes
REM-00179	genai.owasp.org:443 (ASSET-00066)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG: [genai.owasp.org:443] Missi	Enforce baseline HTTP response security headers on origin https://genai.owasp.org:443: Content-Security-Policy, X-Frame-Options (or fra	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG on genai.owa
REM-00180	vwad.owasp.org:443 (ASSET-00068)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG: [vwad.owasp.org:443] Missing	Enforce baseline HTTP response security headers on origin https://vwad.owasp.org:443: Content-Security-Policy, X-Frame-Options (or fram	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG on vwad.owasp
REM-00181	github.com:443 (ASSET-00056)	P3-Backlog	open	Remediate HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA: [github.com:443] Missin	Enforce baseline HTTP response security headers on origin https://github.com:443: Content-Security-Policy, X-Frame-Options (or frame-an	Verification Test: TrePath Retest Adapter for HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA on githu
REM-00182	portswigger.net:443 (ASSET-00058)	P3-Backlog	open	Remediate HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY: [portswigger.net:443]	Enforce baseline HTTP response security headers on origin https://portswigger.net:443: Content-Security-Policy, X-Frame-Options (or fra	Verification Test: TrePath Retest Adapter for HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY on port
REM-00183	www.hackthissite.org:443 (ASSET-00062)	P3-Backlog	open	Remediate ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG: [www.hackthissite.org] [WebPulse] HTML	Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies. [Affected Asse	Verification Test: TrePath Retest Adapter for ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG on www.hackthissite.org:
REM-00184	portswigger.net:443 (ASSET-00058)	P3-Backlog	open	Remediate DAST-ADMIN-ACCESS-EP-01934: [ADMIN-ACCESS-001] Candidate Route or Login Interface Dis	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS	Verification Test: TrePath Retest Adapter for DAST-ADMIN-ACCESS-EP-01934 on portswigger.net:443 (ASSET-00058) | Clo
REM-00185	www.root-me.org:443 (ASSET-00063)	P3-Backlog	open	Remediate DAST-ADMIN-ACCESS-EP-02066: [ADMIN-ACCESS-001] Candidate Route or Login Interface Dis	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS	Verification Test: TrePath Retest Adapter for DAST-ADMIN-ACCESS-EP-02066 on www.root-me.org:443 (ASSET-00063) | Clo
REM-00186	github.com:443 (ASSET-00056)	P3-Backlog	open	Remediate API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI: [github.com:443] API Rate-	Emit standardized RFC-draft RateLimit-* response headers on API endpoints and verify edge/gateway throttling thresholds. [Affected Asse	Verification Test: TrePath Retest Adapter for API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI on github.c

Task ID	Origin Host:Port (Asset)	Priority	Status	Work Package Title	Origin-Accurate Fix Guidance	Verification & Closure Rule
REM-00187	www.root-me.org:443 (ASSET-00063)	P3-Backlog	open	Remediate DAST-API-AUTHZ-EP-02061: [API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Obse	No remediation required for intentional anti-bot/honeypot challenge endpoints; verify WAF/bot-protection rules. [Affected Asset: www.ro	Verification Test: TrePath Retest Adapter for DAST-API-AUTHZ-EP-02061 on www.root-me.org:443 (ASSET-00063) | Closur

8.1A Seven-Step Remediation & Retest Verification Loop (RTEX Lifecycle)

Step	RTEX Lifecycle Stage	Current Status	Verification & EvidenceCore Protocol
Step 1	Baseline Finding Sealed (T0)	COMPLETED	17 consolidated findings sealed with 9-field provenance & 64-hex SHA-256.
Step 2	Remediation Assigned (REM-xxxxx)	COMPLETED	17 origin-bound RemediationTask work packages generated.
Step 3	Deterministic Retest Executed	STANDBY_AWAITING_FIX	0 live retest execution(s) recorded via POST /api/v1/findings/{id}/retest/execute.
Step 4	Negative-Control Validation	READY	Verifies response is not a generic WAF block, anti-bot challenge, or out-of-scope redirect.
Step 5	EvidenceCore Retest Sealing	READY	Before/after HTTP or TCP transcript sealed with fresh FIPS 180-4 SHA-256 digest.
Step 6	Closure Decision (REMEDIATION_VERIFIED)	PENDING_CLOSURE	Promotes Finding to REMEDIATION_VERIFIED only when deterministic control check passes.
Step 7	T1 Post-Retest Risk Recalculation	HYPOTHETICAL_FORECAST_ONLY	Recalculates live T1 risk index; until retest executes, 2.1/10 remains labeled HYPOTHETICAL_PROJECTION.

8.2 Deterministic Retest Execution Ledger (RTEX-xxxxx)

Retest Key	Target Finding	Execution Status	Resulting Proof State	Evidence Artifact	Verification Notes
RTEX-STANDBY	All Open Findings	AWAITING_PATCH	PENDING_RETEST	EvidenceCore Ready	Use POST /api/v1/findings/{id}/retest/execute after applying remediation to record cryptographic closure proof.

9. EvidenceCore Cryptographic Integrity, RFC 8032 Ed25519 Signature Bundle & Quality Gates

9.0 Verifiable RFC 8032 Ed25519 Signature & Tamper-Detection Bundle (Issue 5)

Signing Algorithm & Authority	Ed25519 (RFC 8032) + SHA-256 (FIPS 180-4) | Signer: TrePath-EvidenceCore-Authority-v2.4
Trusted Signing Timestamp	2026-11-02T18:55:03.849060+00:00
Canonical Manifest SHA-256	bdd20f14b4c751e849d9b80ba6656c3529bc5cebca76521f2fbf44226cd23043
Ed25519 Signature (128-Hex)	dcc4b43ce20085c7038c538d4945e1f6e4dc2a42294e04fec908690f689e6cb96772ccd8c262affbd269aa6c8adec57fdeb2bc233bcdaf0df5f6e97922161607
Ed25519 Signature (Base64)	3MS0POIAhccDjFONSUXh9uTcKkIpTgT+yQhpD2iebLlncszYwmKv+9JpqmyK3sV/3rK8IzvNrw319ul5IhYWBw==
Public Key Fingerprint SHA-256	bc91f1e0b7c69696547e1efa0f05a7f9c1a201abf0cf80dabf698e43624c7eb1
Public Key (Raw Hex / PEM)	Hex: 61e14ce688b5c816bcc76b30bcc93c9c2914fa085a2ff326594cd1c5565f05b9 | PEM: -----BEGIN PUBLIC KEY----- MCowBQYDK2VwAyEAYeFM5oi1yBa8x2swvMk8nCkU+ghaL/MmWUzRxVZfBbk= -----END PUBLIC KEY-----
Signature Verification Result	VERIFIED_AUTHENTIC (Bound Artifacts: 198)
Live Tamper-Detection Self-Test	PASSED (Tampered Manifest Deterministically Rejected) - 1-bit payload mutation + 1-byte signature mutation deterministically rejected by Ed25519 verifier.

9.1 Automated Acceptance & Negative Quality Gates (AT-01..AT-10 + NG-01..NG-06)

Gate ID	Verification Domain	Dynamic Acceptance & Negative Quality Gate Rule	Status
AT-01/02	Scope & Redirect Provenance	7-stage scope funnel reconciled (46 requested -> 14 origin assets); external links isolated.	**PASSED**
AT-03..06	Proof-State Reconciliation	**Executive, Section 1.2 & Stage 9 agree: CONFIRMED_ADMIN_AUTH=0, IMPACT_VERIFIED=0.**	**PASSED**
AT-07/08	Risk & Port Reconciliation	4-State port discovery reconciled (0 TCP ports, 376 HTTP endpoints); 7 risk dimensions sum (41.1/100) matches headline (41.1/100).	**PASSED**
AT-09/10	Origin Consolidation & Ed25519	181 raw observations -> 17 unique findings; Consistency=100.0%, Ed25519=VERIFIED_AUTHENTIC.	**PASSED**
NG-01	No Admin Exposure Claim from Route Rea	Candidate /dashboard or /admin HTTP 200 routes without verified admin console controls classified as OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED (Low).	**PASSED**
NG-02	No Outdated Software Claim for Current	Modern versions (e.g. nginx 1.31.8) marked is_outdated=False; banner-only fingerprints use OBSERVATION_CONFIRMED :: VERSION_FINGERPRINT_BANNER_ONLY.	**PASSED**
NG-03	No API Vulnerability Claim from Anti-B	Anubis / /.within.website/ honeypot and public API routes classified as OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED (Low).	**PASSED**
NG-04	No Rate-Limit Absence Claim from Missi	Absent X-RateLimit-* headers classified as OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED (Low).	**PASSED**
NG-05	Zero Cross-Asset Contamination in Reme	All 17 RemediationTask rows bound to exact finding asset_id and effective_origin host:port.	**PASSED**
NG-06	No Unverified Post-Remediation Risk Cl	Executed retests = 0; post-hardening 2.1/10 explicitly labeled HYPOTHETICAL_PROJECTION.	**PASSED**

10. Unified Security Platform Integration (XTRIKE SAST + TrePath 2.4 + Expedite Strike + Noctis)

10.0 Unified Finding Registry (Code Source-to-Sink -> Runtime Verification -> RTEX -> Noctis)

Unified ID	Finding (Asset)	XTRIKE SAST Code Location	Expedite Strike / EVE State	4-Track Score Summary	Noctis Posture State
UFR-042-001	F-01 (ASSET-00055)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:5.5 | Ctrl:40.7	ACTIVE_TELEMETRY_WATCH
UFR-042-002	F-02 (ASSET-00057)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:5.5 | Ctrl:40.7	ACTIVE_TELEMETRY_WATCH
UFR-042-003	F-03 (ASSET-00061)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:5.5 | Ctrl:40.7	ACTIVE_TELEMETRY_WATCH
UFR-042-004	F-04 (ASSET-00064)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:5.5 | Ctrl:40.7	ACTIVE_TELEMETRY_WATCH
UFR-042-005	F-05 (ASSET-00065)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:5.5 | Ctrl:40.7	ACTIVE_TELEMETRY_WATCH
UFR-042-006	F-06 (ASSET-00066)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:5.5 | Ctrl:40.7	ACTIVE_TELEMETRY_WATCH
UFR-042-007	F-07 (ASSET-00068)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:5.5 | Ctrl:40.7	ACTIVE_TELEMETRY_WATCH
UFR-042-008	F-08 (ASSET-00056)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:3.2 | Ctrl:24.6	ACTIVE_TELEMETRY_WATCH
UFR-042-009	F-09 (ASSET-00058)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:3.2 | Ctrl:24.6	ACTIVE_TELEMETRY_WATCH
UFR-042-010	F-10 (ASSET-00059)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:3.2 | Ctrl:24.6	ACTIVE_TELEMETRY_WATCH
UFR-042-011	F-11 (ASSET-00060)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:3.2 | Ctrl:24.6	ACTIVE_TELEMETRY_WATCH
UFR-042-012	F-12 (ASSET-00063)	server.ts:118	CONTROL_GAP_CONFIRMED	CVSS:3.2 | Ctrl:24.6	ACTIVE_TELEMETRY_WATCH

Unified ID	Finding (Asset)	XTRIKE SAST Code Location	Expedite Strike / EVE State	4-Track Score Summary	Noctis Posture State
UFR-042-013	F-13 (ASSET-00062)	External Surface (DAST)	OBSERVATION_CONFIRMED	CVSS:N/A (Observation) | Ctrl:0.0	ACTIVE_TELEMETRY_WATCH
UFR-042-014	F-14 (ASSET-00058)	External Surface (DAST)	OBSERVATION_CONFIRMED	CVSS:N/A (Observation) | Ctrl:0.0	ACTIVE_TELEMETRY_WATCH
UFR-042-015	F-15 (ASSET-00063)	External Surface (DAST)	OBSERVATION_CONFIRMED	CVSS:N/A (Observation) | Ctrl:0.0	ACTIVE_TELEMETRY_WATCH
UFR-042-016	F-16 (ASSET-00056)	server.ts:118	OBSERVATION_CONFIRMED	CVSS:N/A (Observation) | Ctrl:0.0	ACTIVE_TELEMETRY_WATCH
UFR-042-017	F-17 (ASSET-00063)	External Surface (DAST)	OBSERVATION_CONFIRMED	CVSS:N/A (Observation) | Ctrl:0.0	ACTIVE_TELEMETRY_WATCH

10.1 Autonomous 9-Stage Orchestration Architecture & Centralized Version Manifest

Stage	Engine Module (Version)	Execution Outcome
Stage 1-2	Scope & WebPulse 2.4	Verified 14 in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)), 0 open TCP ports, and 376 HTTP endpoints.
Stage 3	ENUMCORE 2.4	Mapped CPEs and separated precondition-verified KEVs from banner-only candidates.
Stage 4-5	HeaderPolicyEvaluator 2.4 & EVE 2.4	Enforced RoE scope lock & read-only HTTP DAST checks (0 destructive or out-of-scope PoCs executed).
Stage 6-7	Expedite Strike 2.4 & AttackGraph 2.4	Assigned 4-level admin boundary taxonomy and built per-edge evidence-backed attack chains.
Stage 8-9	RiskEngine 2.4, RTEX 2.4 & Noctis 2.4	Computed 7-dimension risk (T0=4.1/10, T1=4.1/10) and signed RFC 8032 Ed25519 manifest.

11. Sign-Off & Deliverables Attestation (TrePath 2.4 Unified Release)

Role	Attestation Statement	Signature / Timestamp
Lead Penetration Tester	All findings, origins, and PoC transcripts verified against EvidenceCore SHA-256 & Ed25519 seals.	SIGNED | 2026-11-02 14:53 UTC
Principal Security Architect	TrePath 2.4 (TP24-BUILD-20261102-UNIFIED) AT-01..AT-10, NG-01..NG-06 & 26/26 Quality Gates passed.	VERIFIED | 2026-11-02 14:53 UTC
Client System Owner	Acknowledges receipt of prioritized remediation roadmap and RTEX retest workflow.	_____